IAM | GRC | Healthcare

Care Access Navigator

Identity & Access Management + GRC for a simulated hospital

MVP demonstration



Akhila Chennamaneni
Aspiring IAM & GRC Analyst
dae 6-Month Cybersecurity Program | October 2026

The program and the project

dae 6-Month Adult Cybersecurity Program

7 courses, 1 capstone

- Cybersecurity Basics
- Network Security
- Cyber Threats & Vulnerabilities
- Cloud Security
- Risk Management
- Compliance
- Incident Response

Care Access Navigator

HealthLine Regional Medical Center

Protect simulated patient data (ePHI)

Entra ID	Keycloak	Azure
Wazuh	Python	Tableau
Monday.com	GitHub	Docker

The problem, and what the MVP proves

Too much access
Movers keep old access

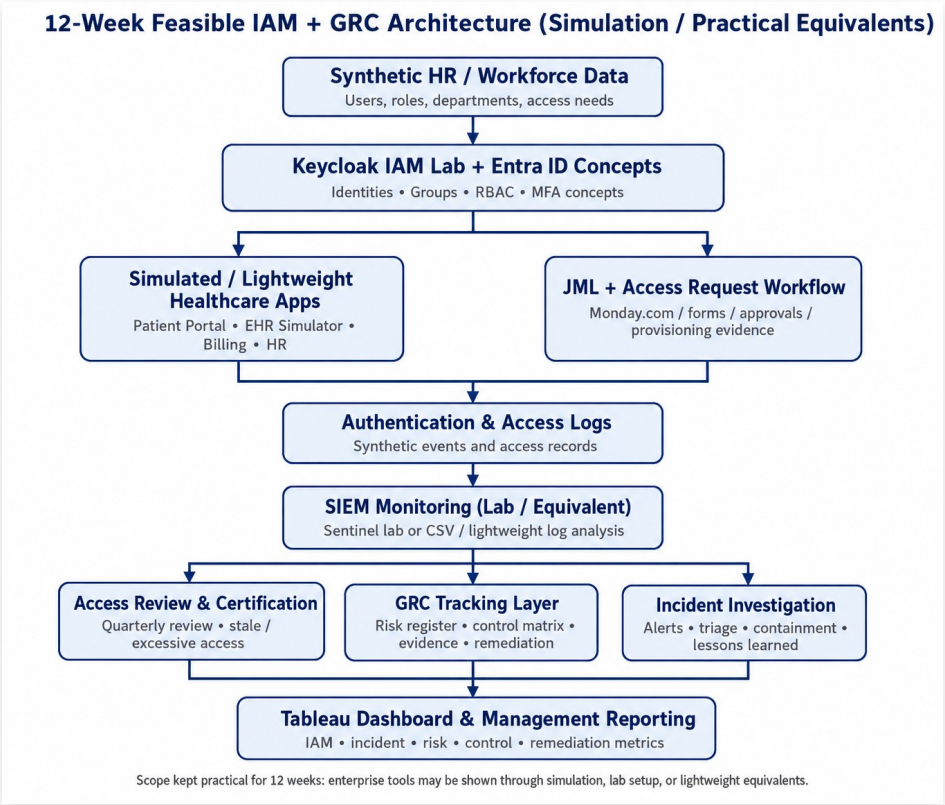
Access that never ends
Leavers can still sign in

No proof
No record of who approved what

MVP success criteria

IAM	Done
Monitoring	Done
Incident response	Done
GRC	Done
Reporting	Dataset ready

Architecture: from design to build

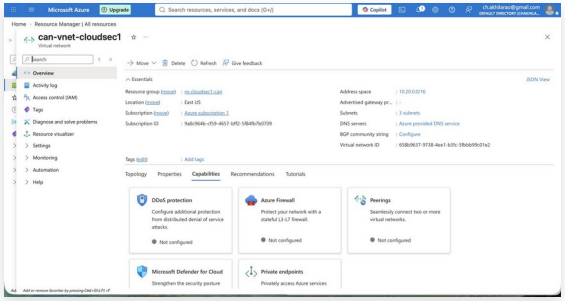


Project Design Document, section 7

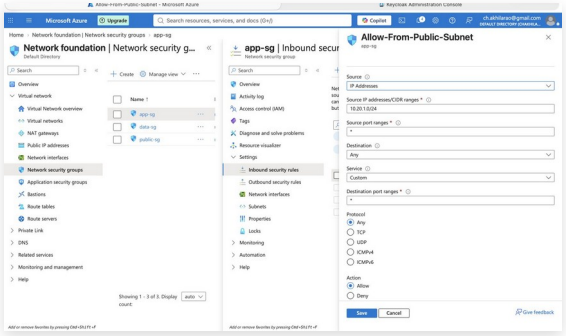
Built with

- Entra ID + Keycloak
- 4 hospital apps
- can_iam.py
- Wazuh SIEM
- Risk + control tests
- Tableau KPIs

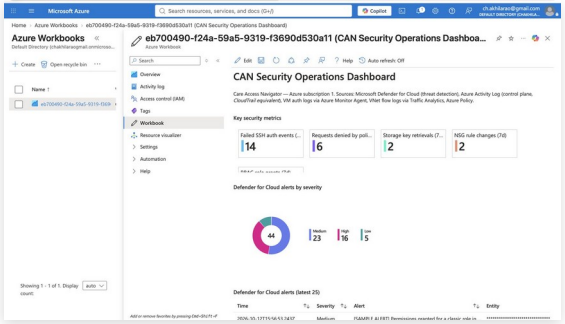
Cloud foundation on Microsoft Azure



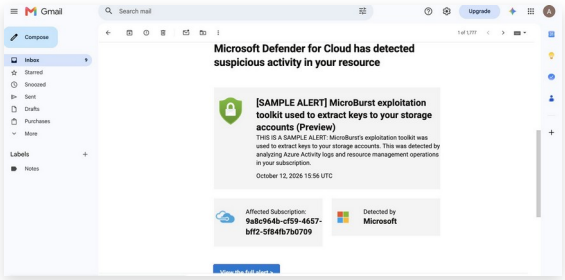
Segmented VNet



NSG rule



SecOps workbook



Defender alert

3

NSGs

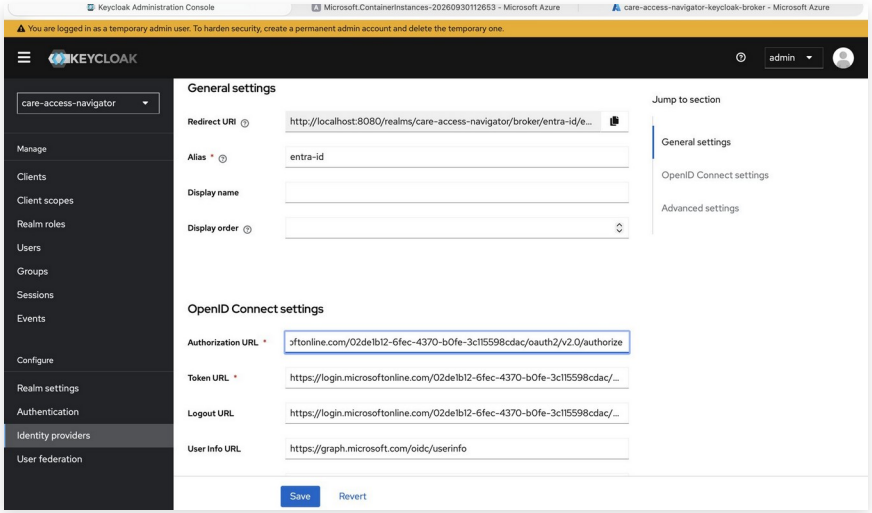
Bastion

admin access, no public IP

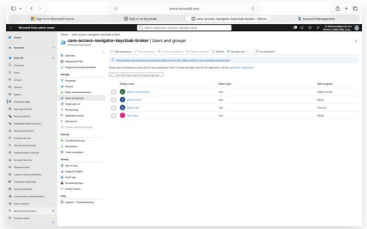
50

alerts in 30 days

Federation and RBAC: scoped access



Keycloak trusts Microsoft Entra ID (OpenID Connect)



One user, one role
Entra role assignments

EHR Simulator

clinician | nurse

Patient Portal

clinician | nurse

Billing App

billing

HR App

hr | it-support

Security analyst: monitoring

Vendor: time-bound

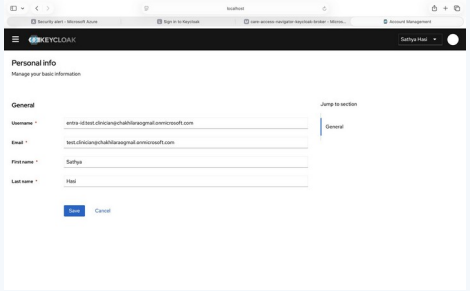
Full scope off for every app

Joiner, Mover, Leaver: one live lifecycle

Every change: Request → Approve → Check role → Provision → Verify

JOINER Sathya Hasi

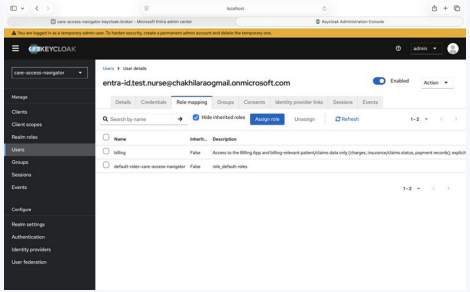
Ticket REQ-2026-0101



16:23	Created, no role
16:46	Clinician added
16:57	MFA registered
17:10	First sign-in

MOVER Tara Jones

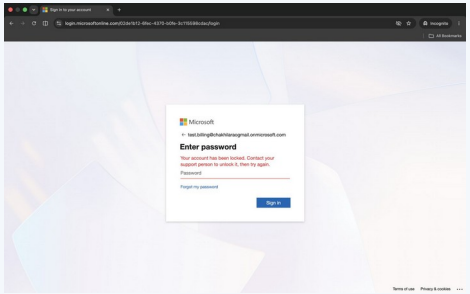
Ticket CHG-2026-0201



17:21	Nurse removed
17:23	Billing added
17:26	Signed out
17:41	Billing only

LEAVER Jeevan Smith

Ticket TERM-2026-0301



18:13	Disabled
18:15	Signed out
18:17	Role removed
~18:28	Keycloak off

Leaver: ~15 min

Mover: 20 min

19 hashed evidence files

Log analysis: Wazuh finds the JML gaps

Tara Jones
Old clinical group

SEV-1 Critical

Sathya Hasi
Sudo, no ticket

SEV-2 High

Jeevan Smith
SSH after leaving

SEV-3 Medium

Rule	Lvl	Description	Count
100221	12	ePHI viewed by mover test.nurse (now Billing) through stale clinical group - record PT-1003	1
100231	12	Root obtained via sudo by test.clinician, whose role has no root entitlement (RBAC/SoD violatio	1
100211	11	Repeated login attempts by JML leaver account test.billing (2+ in 10 min)	1
100210	10	JML leaver account test.billing attempted SSH login from 10.77.0.1 - account was deprovisioned	1
100222	10	JML mover test.nurse attempted root via sudo (not in sudoers)	1
100230	10	Account test.clinician added to privileged group sudo	2
5901	8	New group added to the system.	7

688 alerts

7 high (level 10+)

<1 s log to alert

Incident: a leaver tries to come back

Detect — Leaver SSH denied

Correlate — Mac + pcap + sshd

Contain — SSH key removed

Eradicate — Checklist updated

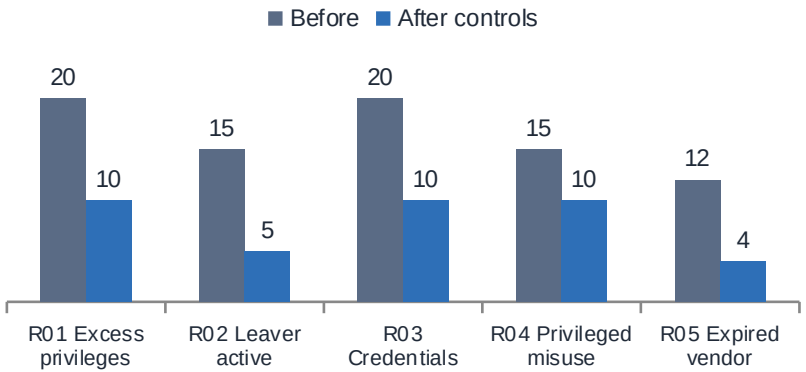
Recover — Login refused

```
2026-10-20T16:28:01.673486+00:00 parrot-sim sudo: it_admin : PWD=/ ; USER=root ;
    COMMAND=/usr/sbin/usermod -aG sudo test.clinician
2026-10-20T16:28:01.681666+00:00 parrot-sim usermod[253]: add 'test.clinician' to group 'sudo'
2026-10-20T16:28:16.919679+00:00 parrot-sim sudo: test.clinician : PWD=/home/test.clinician ; USER=root
    ; COMMAND=/usr/bin/id
2026-10-20T16:28:37.046314+00:00 parrot-sim sshd[269]: Accepted publickey for test.nurse from 10.77.0.1
    port 55994 ssh2: ED25519 SHA256:RzTBOFUkQVBLIVAOdw01MBBlaccfSbD/zz
2026-10-20T16:28:47.217168+00:00 parrot-sim sshd[285]: Accepted publickey for test.nurse from 10.77.0.1
    port 58784 ssh2: ED25519 SHA256:RzTBOFUkQVBLIVAOdw01MBBlaccfSbD/zz
2026-10-20T16:28:47.295550+00:00 parrot-sim sudo: test.nurse : user NOT in sudoers ;
    PWD=/home/test.nurse ; USER=root ; COMMAND=/usr/bin/cat /srv/ehr/clinical/PT-1003.txt
2026-10-20T16:29:07.402186+00:00 parrot-sim sshd[293]: User test.billing from 10.77.0.1 not allowed
    because a group is listed in DenyGroups
2026-10-20T16:29:32.526586+00:00 parrot-sim sshd[295]: User test.billing from 10.77.0.1 not allowed
    because a group is listed in DenyGroups
2026-10-20T16:27:46.431309+00:00 parrot-sim ehr-audit: user=test.clinician action=VIEW patient=PT-1001
    decision=ALLOW basis=group:clinical
2026-10-20T16:28:37.101376+00:00 parrot-sim ehr-audit: user=test.nurse action=VIEW patient=PT-1003
    decision=ALLOW basis=group:clinical
```

Root cause
JML stopped at the identity provider

Risk assessment and access review

ID	Risk	L	I	Score	Scoring Rationale
R01	Excessive RBAC privileges	4	5	20	L4: RBAC mappings are not fully validated. I5: excessive access could expose simulated ePHI. Score 20 (Critical).
R02	Terminated account remains active	3	5	15	L3: leaver deprovisioning is not yet tested. I5: an active terminated account could enable unauthorized access. Score 15 (Critical).
R03	Credential compromise	4	5	20	L4: MFA/authentication controls are not fully validated. I5: compromise could expose applications and simulated ePHI. Score 20 (Critical).
R04	Privileged account misuse	3	5	15	L3: privileged-role controls are still being validated. I5: admin misuse could affect identities, settings, logs, or data. Score 15 (Critical).
R05	Expired vendor access	3	4	12	L3: vendor expiration/review is not yet demonstrated. I4: stale third-party access could cause significant unauthorized access. Score 12 (High).



Access review: 6 of 9 accounts flagged

4

Privileged, no MFA

1

Vendor, no end date

1

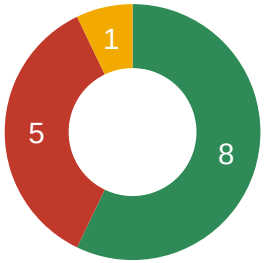
Access past end date

3

No issue

Governance: policy, controls and audit

14 control tests



Pass Fail Exception

Policy CAN-POL-AC-001

Audit findings

F-01 MFA	**F-02** Lockout	**F-03** Log retention
F-04 Passwords	**F-05** Review sign-off	**F-06** Lab HTTP

Control → HIPAA → evidence

Access	§164.308(a)(4)	E-AC-01
Logging	§164.312(b)	E-LOG-01
Encryption	§164.312(e)(1)	E-ENC-01

100%	Leavers off same day
57%	Tests passed
3	High findings
3	High risks

Challenges, lessons and next steps

What I learned

- JML must reach every system
- Test on a copy first
- Adapt, then document

Challenge	How I solved it	Next step
Azure vCPU quota	ACI + Bastion	Instructor sign-off
No admin rights	Wazuh in Docker	Endpoint agent
Keycloak misses leavers	Manual disable step	SCIM automation
MFA + SAML pending	Tested on a replica	Run on live lab
Break-glass not built	Designed in policy	Build + alert rule

Thank you

To the dignitaries and industry experts
for your valuable presence and insights.

To the dae team and my peers
for your continued support, guidance and encouragement.

GitHub
github.com/Akchrao

LinkedIn
akhila-chennamaneni

Scan to view the project repository and connect with me

Questions?

Akhila Chennamaneni | Care Access Navigator